

جلسه دوم دوره آموزشی ارزیابی امنیتی سامانه‌های نرم‌افزاری تحت وب

سامانه‌های نرم‌افزاری تحت وب (web application) تحت فریمورک و استانداردهای مختلفی ارزیابی امنیتی از جمله owasp otg و owasp wstg و asvs می‌شوند.

- در مورد تفاوت framework و standard مطالعه کنید. Owasp otg , Owasp wstg فریمورک هستند و asvs استاندارد ارزیابی امنیتی است.

هدف آموزشی ما در این دوره Owasp OTG است.

Owasp (Open Worldwide Application Security Project) یک نهاد غیردولتی است که در زمینه امنیت نرم‌افزار فعالیت می‌کند و تحقیقات، استانداردها و ابزارهای متنوعی در این حوزه به صورت متن‌باز منتشر می‌کند.

از آدرس زیر می‌توانید نسخه آخر از owasp otg را دانلود کنید.

https://owasp.org/www-project-web-security-testing-guide/assets/archive/OWASP_Testing_Guide_v4.pdf

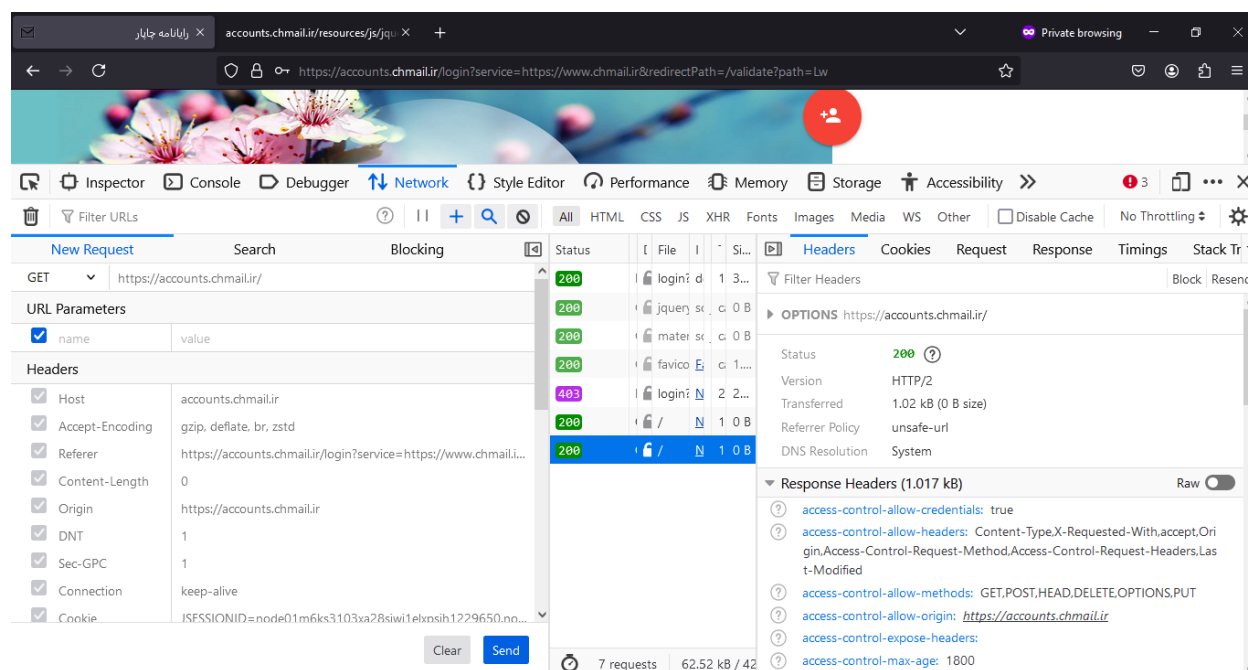
اگر صفحه ۲۱۱ این مستند را مشاهده کنید، شامل ۱۱ بخش زیر است:

- جمع آوری اطلاعات information Gathering
- تست پیکربندی و نحوه استقرار Configuration and Deploy Management Testing
- تست مدیریت هویت Identity Management Testing
- تست کنترل دسترسی Authorization Testing
- تست مدیریت نشست Session Management Testing
- تست ورودی‌ها Input Validation Testing
- مدیریت خطاها Error Handling
- رمزنگاری Cryptography
- تست منطق کسب‌وکار Business Logic Testing
- تست سمت کاربر Client Side Testing

هریک از این ۱۱ بخش دارای زیرمجموعه‌ها (آیتم تست‌هایی) هستند که در این مستند به شکل otg-...-number مشخص می‌شوند. هر آیتم تست دارای توضیحات مختصر، اهداف تست و نحوه انجام تست است.

به صورت کلی، هدف در تست امنیتی یک نرم‌افزار این است که از طریق دستکاری request ها، یک ضعف از نظر محرمانگی (confidentiality)، در دسترس پذیری (availability) یا یکپارچگی (integrity) ایجاد کرده و سپس این ضعف به مالک محصول گزارش گردد تا نقص مورد نظر برطرف شود.

تصویر زیر نشان می‌دهد که امکان دستکاری request ها و تحلیل response ها از طریق مرورگر نیز وجود دارد اما برای راحت‌تر بودن و سریع‌تر دستکاری کردن request ها و کنترل بیشتر روی آنها، ابزارهای متنوعی وجود دارد که معروف‌ترین آنها در حوزه امنیت نرم‌افزار burp suit است.



در جلسه‌های آینده راجع به ابزار burp suit توضیح داده خواهد شد.

در ادامه بخش‌های مختلف مستند owasp otg بررسی می‌شود.

- جمع آوری اطلاعات information Gathering

هدف کلی این بخش این است که از انواع روش‌ها، حداکثر اطلاعات در مورد محصول نرم‌افزاری تحت تست (target of evolution یا به اختصار TOE) جمع‌آوری گردد. از این اطلاعات جمع‌آوری شده در بخش‌های بعد برای تست و ارزیابی استفاده خواهد شد. این بخش شامل ۱۱ زیرمجموعه است که در مستند owasp otg مشاهده می‌شود.

Otg-info-001

Conduct Search Engine Discovery and Reconnaissance for Information Leakage

در این آیتم تست، ارزیاب باید تلاش کند تا با استفاده از موتورهای جستجو (مثل گوگل، duck duck go و ...) نشت - های اطلاعاتی در مورد یک نرم افزار تحت وب را شناسایی کند.

موتورهای جستجو از آنجایی که مدام در حال crawl کردن (شخم زدن) اینترنت و سرویس های اینترنتی هستند، ابزار خیلی خوبی برای شناسایی هر آن چیزی هستند که یک نرم افزار تحت وب ممکن است بخواهد از یک ارزیاب امنیتی پنهان کند. یا زمان زیادی طول بکشد تا ارزیاب امنیتی یک مسیر یا یک فایل را پیدا کند ولی یک موتور جستجو که مدام در حال crawl کردن است، پیشتر آن را پیدا کرده باشد.

با تجربه بیشتر متوجه خواهید شد که روی هر سایت (محصول تحت تست) در موتورهای جستجو دنبال چه چیزی بگردید. این موضوع بستگی زیادی به ماموریت سامانه، تکنولوژی های آن و ... دارد.

لینک زیر کمک زیادی به شما خواهد کرد تا این جستجو ها را بسازید. به این شکل جستجو dork گفته می شود. البته موتورهای جستجو بسیاری وجود دارد که اهداف متنوعی دارند اما بکارگیری google در این بخش کافی است.

<https://pentest-tools.com/information-gathering/google-hacking>

تمرین:

۱. مطالعه و انجام آزمون های کامل بخش information gathering (تمام ۱۱ آیتم) روی سایت namava.ir و مستند سازی در قالب یک فایل word

برنامه جلسه آینده:

۱. اجرای عملی یکی از آیتم تست ها و مستند سازی

۲. بررسی آزمون های بخش configuration and deploy management testing